STRIPE AI INFRASTRUCTURE • CERTIFICATION BLOC 2 (RNCP 41993)

Sécurité, Gouvernance des Données & Conformité Réglementaire

En tant qu'opérateur financier mondial, Stripe est soumis aux réglementations les plus strictes de l'industrie : - **PCI-DSS v4.0 Level 1 (Payment Card Industry Data Security Standard) :** Exige l'isolation totale des données de cartes bancaires (PAN, CVV, code PIN), un chiffrement fort systématique et un audit continu des accès. - **RGPD (Règlement Général sur la Protection des Données) :** Impose la souveraineté territoriale des données des citoyens européens, la minimisation des collectes, la pseudonymisation et le respect du droit à l'oubli.

1.1. Architecture "Tokenization Vault" & Isolation PCI-DSS

Pour minimiser le périmètre de conformité PCI (*PCI Scope Reduction*), aucun numéro de carte de crédit (PAN) ne pénètre dans les bases applicatives de Stripe (ni OLTP, ni OLAP, ni NoSQL, ni Data Lake) : 1. **Interception à l'Edge :** Les formulaires Stripe Checkout / Elements injectent les données de carte directement dans un **coffre-fort de tokenisation isolé** certifié PCI-DSS Level 1 (hébergé dans un VPC dédié et chiffré par un module HSM matériel AWS CloudHSM). 2. **Émission d'un Token non réversible :** Le coffre-fort renvoie un token opaque (`pm_1J8x92...`) et les 4 derniers chiffres (`card_last4`). Seul ce token est manipulé par l'API, le moteur de fraude Radar et la base transactionnelle. 3. **Zéro PAN dans les logs :** Des règles de filtrage au niveau d'AWS WAF et des agents d'ingestion Fluentbit masquent systématiquement toute chaîne de 16 chiffres pouvant ressembler à une carte bancaire.

1.2. Chiffrement de Bout en Bout & Gestion des Secrets

- **Chiffrement en Transit :** Toutes les communications réseau (externes et inter-services internes) sont obligatoirement chiffrées en **TLS 1.3** avec des suites cryptographiques modernes (ECDHE-RSA-AES256-GCM-SHA384). Les connexions en clair (HTTP/port 80) sont rejetées par AWS ALB.
- **Chiffrement au Repos :** 100% des volumes de stockage (Amazon EBS pour EKS, disques Aurora PostgreSQL, clusters DocumentDB, Redshift et buckets S3) sont chiffrés à l'aide d'**AWS KMS avec des clés gérées par le client (Customer Managed Keys - CMK)** utilisant l'algorithme **AES-256**. Une rotation annuelle automatique des clés cryptographiques est activée.
- **Gestion Dynamique des Secrets :** Aucun mot de passe, certificat ou token d'API n'est écrit dans le code ou les variables d'environnement. Les microservices EKS s'authentifient via **IAM Roles for Service Accounts (IRSA)** et récupèrent leurs secrets à la volée depuis **AWS Secrets Manager**, avec rotation automatique tous les 30 jours.

2. Matrice des Risques, Mesures & Responsabilités

Risque Identifié	Impact Métier	Mesure de Protection Architecturale	Référence / Norme	Responsable Désigné
Fuite de données de cartes bancaires (PAN/CVV)	Catastrophique (perte d'agrément bancaire, amendes de millions d'€)	Coffre-fort de tokenisation dédié (CloudHSM), zero-PAN dans l'infrastructure de données, masquage WAF.	PCI-DSS v4.0 (Req 3 & 4)	Chief Information Security Officer (CISO)
Accès illégitime ou élévation de privilèges	Majeur (altération de soldes, exfiltration de données marchands)	Principe du moindre privilège via AWS IAM RBAC, zéro port SSH ouvert (accès via AWS Systems Manager Session Manager avec MFA obligatoire).	PCI-DSS (Req 7 & 8) / ISO 27001	Lead Cloud Security Engineer
Non-conformité RGPD & Fuite de PII	Élevé (amendes CNIL jusqu'à 4% du CA mondial)	Pseudonymisation systématique (`email_hash` SHA-256 avec sel), hébergement souverain en France (`eu-west-3`), pipeline d'effacement automatisé (droit à l'oubli).	RGPD Art. 17 & 32	Data Protection Officer (DPO)
Perte de données sur panne de datacenter	Majeur (interruption d'activité, perte financière)	Déploiement multi-zones sur 3 AZs avec Aurora Multi-AZ (réplication synchrone en 6 copies), sauvegardes quotidiennes immuables (S3 Object Lock).	Continuité d'activité / BCP	Lead Database Administrator (DBA)
Attaque par déni de service distribué (DDoS)	Moyen à Élevé (indisponibilité du service de paiement)	AWS Shield Advanced + AWS WAF avec limitation de débit (*rate limiting*) à 2000 requêtes/5min par adresse IP.	Disponibilité / SLA 99.999%	Network & Infrastructure Lead
Altération non détectée des logs d'audit	Majeur (impossibilité d'investigation médico-légale)	AWS CloudTrail consolidé vers un bucket S3 sécurisé avec validation d'intégrité des fichiers journaux (*Log File Validation*) et verrouillage WORM (*Write Once Read Many*).	PCI-DSS (Req 10)	Responsable Audit & Conformité

3. Conformité RGPD & Droit à l'Oubli

Pour respecter l'article 17 du RGPD (droit à l'effacement), Stripe déploie un **orchestrateur d'anonymisation** piloté par Airflow : 1. **Déclenchement :** L'utilisateur ou le marchand soumet une demande d'effacement via l'API GDPR. 2. **Propagation Synchrone OLTP :** L'enregistrement dans `stripe_oltp.customers` est mis à jour : les métadonnées personnelles sont écrasées par des valeurs anonymisées génériques (`DELETED_USER_XXXX`). Les transactions comptables sont conservées avec l'identifiant pseudonyme conformément à l'obligation légale de conservation des livres de comptes pendant 10 ans (Code de commerce). 3. **Propagation Asynchrone (NoSQL & Data Lake) :** Un job Spark lit l'événement de

suppression sur le topic Kafka `stripe.gdpr.requests` et purge les documents associés dans Amazon DocumentDB (`device_fingerprints`) ainsi que les partitions du Data Lake S3.

---

4. Analyse Économique (FinOps) & Estimation Budgétaire AWS

Une estimation budgétaire a été réalisée sur l'**AWS Pricing Calculator** pour dimensionner l'infrastructure européenne de Stripe traitant en moyenne 15 millions de transactions par jour :

4.1. Répartition Estimée des Coûts Mensuels

Service AWS	Rôle dans l'Architecture	Dimensionnement / Type	Coût Estimé / Mois	% Facture
Amazon Aurora PostgreSQL	Base de données OLTP Multi-AZ	`db.r6i.4xlarge` (16 vCPU, 128 Go RAM) + 2 Réplicas de lecture + 2 To stockage io2	~7 500 $	30 %
Amazon EKS & Inférence Radar	Pods FastAPI Inférence Fraude	12 instances `c6i.2xlarge` (Compute-optimized) réparties sur 3 AZs	~3 800 $	15 %
Amazon Redshift Serverless	Data Warehouse OLAP & BI	128 RPU (base) avec mise à l'échelle automatique selon la charge de requêtes	~4 200 $	17 %
Amazon MSK (Kafka)	Bus d'événements de streaming	3 brokers `kafka.m5.2xlarge` (Multi-AZ) + stockage EBS sécurisé	~2 600 $	10 %
Amazon DocumentDB & Redis	NoSQL Telemetry & Feature Store	DocumentDB `db.r6g.xlarge` + ElastiCache Redis Cluster (3 nœuds `cache.r6g.xlarge`)	~2 400 $	10 %
Amazon SageMaker & GPU	Réentraînement périodique ML	Instances GPU éphémères (Job batch hebdo : 8h x `ml.g5.2xlarge`)	~1 100 $	4 %
Amazon S3 & S3 Glacier	Data Lake Bronze/Silver/Gold & Vault	150 To S3 Standard + 400 To Glacier Flexible Archive	~1 900 $	8 %
Réseau, WAF & Sécurité	ALB, NAT Gateways (x3), AWS WAF, KMS	Transfert de données inter-AZ, 3 NAT Gateways, requêtes WAF	~1 500 $	6 %
TOTAL ESTIMÉ	**Infrastructure Complète de Production**	**Haute Disponibilité 3-AZ Région Paris**	**~25 000 $**	**100 %**

4.2. Les 3 Principaux Facteurs de Coût (*Cost Drivers*) & Leviers de Réduction

1. **Poste 1 : Base de Données Transactionnelle Aurora Multi-AZ (~30%)**
2. *Problématique :* Les instances de bases de données tournent 24h/24 avec du stockage haute performance io2 provisionné pour garantir un commit sous les 10 ms.
3. *Levier d'optimisation FinOps :* Souscription d'un engagement **Amazon RDS Savings Plans sur 3 ans**, réduisant le coût de calcul de **38%** (économie de ~2 850 $/mois).
4. **Poste 2 : Data Warehouse Redshift Serverless & Streaming MSK (~27%)**

5. *Problématique :* Les requêtes de reporting des marchands et l'ingestion continue génèrent des coûts soutenus.
6. *Levier d'optimisation FinOps :* Définition de plafonds stricts d'utilisation des RPU (*Usage Limits*) pour Redshift Serverless pendant les heures creuses (22h - 06h), et compactage des micro-batchs Kafka vers S3 pour limiter les requêtes directes.
7. **Poste 3 : Compute d'Inférence EKS & Entraînement SageMaker GPU (~19%)**
8. *Problématique :* Les serveurs GPU et les microservices d'inférence en veille consomment des ressources même en basse saison.
9. *Levier d'optimisation FinOps :* Utilisation exclusive d'**Instances Spot** pour les jobs d'entraînement périodiques SageMaker (économie de **70%** sur le GPU par rapport au tarif à la demande). Sur EKS, activation de l'auto-scaling horizontal (HPA) avec réduction automatique à 3 pods la nuit.

---

5. Note d'Ingénierie Écologique (GreenOps)

Conformément aux exigences de gouvernance et d'éco-conception, l'architecture intègre des principes d'éco-conception logicielle et d'efficacité énergétique : 1. **Sélection de Région à Très Faible Intensité Carbone :** L'infrastructure est hébergée sur la région **AWS Paris (`eu-west-3`)**, qui bénéficie du mix électrique français décarboné (nucléaire et énergies renouvelables). L'intensité carbone moyenne y est d'environ **50 à 60 g CO_2e/kWh**, contre plus de **380 g CO_2e/kWh** pour des régions comme Francfort (`eu-central-1`) ou Virginie du Nord (`us-east-1`). 2. **Élimination du Compute "Zombie" (Anti-Idle Pattern) :** Aucun cluster d'entraînement GPU ne reste alloué en continu. SageMaker instancie les machines GPU uniquement à la seconde où le DAG Airflow démarre le calcul de gradient, et détruit automatiquement les instances dès l'exportation du modèle ONNX vers S3. 3. **Compaction & Compression Optimale des Données :** Le passage systématique des logs et transactions au format **Apache Parquet avec compression Snappy/ZSTD** divise par 4 l'espace disque physique nécessaire et réduit d'autant l'énergie électrique consommée par les serveurs de stockage d'AWS.